

ENGINEERING AUDIT

# PortalX for Android

## V0.2.0

---

Crash, logic, security and design audit of the native Portal One client — with every finding fixed, rebuilt, and tested.

**Package** com.pravahax.portalx.mobile · **Version** 0.2.0 (code 6) · **Previous** 0.1.4 (code 5)  
**Stack** Kotlin 2.0.20 · Jetpack Compose M3 (BOM 2024.09.03) · OkHttp 4.12 · minSdk 26 / target 35  
**Prepared for** Varad, PRAVAHAX · **Date** 08 October 2026 (IST)

## Summary

v0.1.4 installed, signed in and navigated correctly, but a line-by-line audit found **28 issues**: four that could crash the app or corrupt data, eight high-severity security, reliability and maintainability risks, and a set of medium/low issues in flows, dates, validation and polish. All but one are fixed in v0.2.0; the remaining item (H-08, server-function hash fragility) needs a backend change.

**4**

CRITICAL

**8**

HIGH

**9**

MEDIUM

**7**

LOW

### Most important changes

- **Correct records, every time.** Writes now send the server's id as received; v0.1.4 could send `id: 0` for approvals and task updates.
- **No more crash paths** from missing intent handlers, duplicate list keys, the post-password-change call, or malformed server payloads.
- **Session security.** Cookies, session scope and cached data are encrypted with an Android Keystore key; no backup or device-transfer leakage; HTTPS-only with system CAs; secure window on credential screens.
- **Fool-proof actions.** Single-flight buttons, no silent POST replays, confirmations for check-out/reject/sign-out, haptics, offline bar, friendly errors, auto-refresh after actions and on resume.
- **Premium, on-brand UI.** Exact Portal One web tokens (warm parchment slate scale, gold primary), Manrope + Playfair Display, shimmer skeletons, halo empty states, brand hero cards, refined navigation, light and dark.
- **Size.** R8 + resource shrinking: APK 11.96 MB → 2.24 MB, signed with the unchanged release key (installs as an update).

**Verification status.** 27 automated tests pass (unit, MockWebServer API, Robolectric launch and 44 screen renders with realistic and hostile data). Authenticated response shapes and the R8-minified build still need a pass on a real device with a real account — see Known limitations.

# Findings

| ID   | SEVERITY | AREA                   | ISSUE                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | FIX                                                                                                                                                                                                                                                                    | STATUS |
|------|----------|------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| C-01 | Critical | Logic / data integrity | Every write coerced record ids with <code>num("id")?.toLong() ?: 0</code> . A string/UUID or missing id silently became <code>id: 0</code> for <code>DecideLeave</code> , <code>DecideCorrection</code> , <code>UpdateTaskStatus</code> , <code>MarkAnnouncementRead</code> , <code>TaskDetail</code> , <code>AddTaskComment</code> , <code>ApplyLeave</code> (typed) and <code>CreateTask</code> (project/assignee) - approving or updating the wrong record, or failing silently. | New <code>idOf()</code> sends the id exactly as the server returned it (numeric strings become numbers, like the web's <code>Number()</code> ). Action buttons are disabled when a row has no id.                                                                      | Fixed  |
| C-02 | Critical | Crash                  | After a forced password change, <code>scope.launch { auth = repo.me() ... }</code> had no error handling: any network or server error during the follow-up call was an uncaught coroutine exception and crashed the app.                                                                                                                                                                                                                                                            | Change-password flow rewritten: uses the user object the server returns (as the web does), falls back to <code>me()</code> , and handles every error inline. Added a Sign out instead escape hatch.                                                                    | Fixed  |
| C-03 | Critical | Crash                  | <code>startActivity / camera.launch</code> were called without guards. On a device with no camera app, browser, mail or dialer handler (work profiles, kiosk devices) the app crashed with <code>ActivityNotFoundException</code> .                                                                                                                                                                                                                                                 | All external intents go through <code>startSafely() / openWeb()</code> ; camera launch is wrapped and shows a friendly snackbar.                                                                                                                                       | Fixed  |
| C-04 | Critical | Crash                  | LazyColumn item keys were built from ids ( <code>"u"+id</code> , <code>"p"+id</code> , <code>it.str("id")?.hashCode</code> ). Missing or duplicated ids from the server produce duplicate keys, which throws <code>IllegalArgumentException</code> and crashes the screen.                                                                                                                                                                                                          | <code>stableKeys()</code> guarantees unique keys (prefix + id, index fallback, de-duplication). Covered by a unit test and the hostile-data UI smoke test.                                                                                                             | Fixed  |
| H-01 | High     | Security               | Session cookies and the session scope were stored in plaintext <code>SharedPreferences</code> ; cached API responses (profile, directory with emails/phones) were also plaintext.                                                                                                                                                                                                                                                                                                   | New <code>SecureStore</code> : AES-256-GCM with a non-exportable Android Keystore key for cookies, scope and the response cache. v0.1.x data is migrated once and the plaintext files are wiped. If the Keystore is unavailable it runs memory-only (never plaintext). | Fixed  |
| H-02 | High     | Security               | <code>allowBackup="false"</code> does not stop Android 12+ device-to-device transfer; without <code>dataExtractionRules</code> the session could be copied to a new phone.                                                                                                                                                                                                                                                                                                          | Added <code>data_extraction_rules.xml</code> (cloud + D2D exclude everything) and <code>backup_rules.xml</code> for Android 11 and below. Keystore-bound data also becomes undecryptable elsewhere.                                                                    | Fixed  |
| H-03 | High     | Flow / idempotency     | No in-flight guard on writes: double taps on Approve/Reject, Apply, Create task, Break, comment Send and repeated swipe callbacks sent duplicate requests.                                                                                                                                                                                                                                                                                                                          | <code>ActionRunner</code> : per-key single-flight, buttons show an inline progress state and are disabled while running; swipe-to-done is idempotent.                                                                                                                  | Fixed  |

| ID   | SEVERITY | AREA                  | ISSUE                                                                                                                                                                                                                                                                            | FIX                                                                                                                                                                                                                                            | STATUS               |
|------|----------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|
| H-04 | High     | Flow / idempotency    | OkHttp's default <code>retryOnConnectionFailure</code> can transparently replay a POST (check-in, apply leave) on a stale pooled connection.                                                                                                                                     | Writes use a client with retries disabled; reads retry once with backoff. A timed-out write is flagged uncertain and the app re-reads state instead of claiming failure. "Already checked in" is treated as state, not an error.               | Fixed                |
| H-05 | High     | UX safety             | Irreversible actions ran on a single tap: check-out, rejecting leave, rejecting corrections, signing out.                                                                                                                                                                        | Confirmation dialogs (destructive styling for rejects/sign-out). Check-out confirms the IST time before the selfie.                                                                                                                            | Fixed                |
| H-06 | High     | Attendance            | Selfie flow used <code>TakePicturePreview</code> (low-res thumbnail) and kept the pending check-in/out mode in <code>remember</code> . When the camera app causes Android to recreate or kill PortalX, the result was silently dropped. JPEG compression ran on the main thread. | <code>TakePicture</code> into a private FileProvider cache file; mode/path in <code>rememberSaveable</code> ; decode with subsampling, EXIF rotation, scale to 960 px, JPEG 80 on <code>Dispatchers.Default</code> ; temp file always deleted. | Fixed                |
| H-07 | High     | Coroutines            | <code>catch (e: Exception)</code> also caught <code>CancellationException</code> , so navigating away mid-request showed "Can't reach Portal One" errors and broke structured concurrency.                                                                                       | Cancellation is re-thrown everywhere (resources, actions, login, sheets).                                                                                                                                                                      | Fixed                |
| H-08 | High     | API / maintainability | Server-function ids are content hashes of the web build and change on every web redeploy; when they do, every call in the app fails until a new APK ships.                                                                                                                       | Friendly "app may need an update" error on 404/HTML; documented a versioned API recommendation.                                                                                                                                                | Open (needs backend) |
| M-01 | Medium   | Auth state machine    | On launch with a session but no cached profile, any non-401 failure (server down, offline) dropped the user to the login screen although the session was valid. Several concurrent 401s each triggered a logout.                                                                 | Explicit states: Checking, Unavailable (retry / use another account), SignedOut (notice), SignedIn. Sign-out is idempotent and always clears cookies, scope and cache.                                                                         | Fixed                |
| M-02 | Medium   | Validation            | App accepted 8-character passwords; the web enforces at least 12, so the server rejected them.                                                                                                                                                                                   | Validation matches the web (12+, must differ, must match).                                                                                                                                                                                     | Fixed                |
| M-03 | Medium   | Stale data            | After approving leave, checking in or updating tasks, other screens (Home counts, approvals, calendar) kept stale data.                                                                                                                                                          | Invalidation map per server function; resources refetch automatically after related writes and when the app resumes after 60 s.                                                                                                                | Fixed                |
| M-04 | Medium   | Dates / IST           | Date fields were cut with <code>take(10)</code> and compared as strings; a DATE serialised as IST midnight ( <code>2026-10-06T18:30Z</code> ) showed as the previous day and tasks were marked overdue a day early. Times used the device zone.                                  | <code>Dates</code> helper: everything is parsed into Asia/Kolkata; day fields convert to IST before taking the date; overdue uses real date comparison.                                                                                        | Fixed                |
| M-05 | Medium   | Leave                 | End date could be set before start; half day allowed for multi-day ranges; no length limit; no balance feedback.                                                                                                                                                                 | Validation with inline errors, day count, balance warning, end-date picker limited to $> =$ start, half day locks end = start, 500-char reason.                                                                                                | Fixed                |

| ID   | SEVERITY | AREA       | ISSUE                                                                                                                                                                                  | FIX                                                                                                                                                                               | STATUS |
|------|----------|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| M-06 | Medium   | Robustness | Seroyal decoder used <code>!!</code> , unchecked <code>jsonPrimitive</code> casts and substring escapes that throw on malformed input; mismatched key/value arrays threw index errors. | Decoder is total (never throws), supports Date/Map/Set/BigInt/Error/Boxed nodes, guards depth, and is covered by unit tests with garbage input.                                   | Fixed  |
| M-07 | Medium   | Lifecycle  | Repo/OkHttp/cookie jar were rebuilt on every rotation; login fields were lost on rotation; a global mutable <code>LocalRepoHolder.repo!!</code> was used from lambdas.                 | Process-wide singletons in <code>PortalXApp</code> ; saveable form state (password intentionally not saved); global holder removed.                                               | Fixed  |
| M-08 | Medium   | Offline    | No global offline indication; raw exception text could reach users.                                                                                                                    | Connectivity monitor with an app-wide offline bar; actions disabled offline on Attendance/Leave; every error mapped to a friendly message (offline, timeout, TLS, 5xx, 403, 404). | Fixed  |
| M-09 | Medium   | Auth       | Forced password change screen had no way to sign out.                                                                                                                                  | "Sign out instead" added.                                                                                                                                                         | Fixed  |
| L-01 | Low      | Security   | No explicit network security config.                                                                                                                                                   | HTTPS-only, system CAs only (user-installed CAs not trusted), <code>usesCleartextTraffic=false</code> .                                                                           | Fixed  |
| L-02 | Low      | Security   | Credential screens could be screenshotted / shown in Recents.                                                                                                                          | <code>FLAG_SECURE</code> while login and change-password are visible.                                                                                                             | Fixed  |
| L-03 | Low      | Security   | Server-provided meeting links were opened if they merely started with "http".                                                                                                          | Only http(s) URLs with a host are opened; javascript:/intent:/file: rejected; mailto/tel built with <code>Uri.fromParts</code> .                                                  | Fixed  |
| L-04 | Low      | Build      | R8 disabled; 12 MB APK.                                                                                                                                                                | R8 + resource shrinking with keep rules (app package kept whole; OkHttp/kotlinx rules). Toggle: <code>-Pportalx.minify=false</code> .                                             | Fixed  |
| L-05 | Low      | Battery    | Clock/timer loops kept ticking while the app was in the background.                                                                                                                    | Lifecycle-aware <code>rememberNow()</code> pauses below STARTED.                                                                                                                  | Fixed  |
| L-06 | Low      | UI         | Dark status-bar icons on the dark login panel in light mode; spinners and skeletons shown together; "null day(s)" and "4.0" formatting.                                                | Per-screen system-bar icon contrast; skeletons for first load, pull indicator only for user refresh; number formatting helper.                                                    | Fixed  |
| L-07 | Low      | Networking | Cookie jar keyed by cookie name only; User-Agent hard-coded 0.1.                                                                                                                       | Keyed by <code>nameAndDomainPath</code> ; UA uses BuildConfig version.                                                                                                            | Fixed  |

## Security review

| CONTROL                    | V0.1.4                                                                        | V0.2.0                                                                                                                                                                                                                                                          |
|----------------------------|-------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Session storage</b>     | Cookies + scope in plaintext<br>SharedPreferences                             | AES-256-GCM, non-exportable Android Keystore key ( <code>SecureStore</code> ). One-time migration, plaintext files wiped. Keystore failure $\Rightarrow$ memory-only, never plaintext. Decrypt failure $\Rightarrow$ wipe and sign out (no crash).              |
| <b>Cached API data</b>     | Plaintext (profile, directory with emails/phones)                             | Encrypted with the same store; cleared on sign-out and on a new sign-in.                                                                                                                                                                                        |
| <b>Backup / transfer</b>   | <code>allowBackup=false</code> only (Android 12+ D2D transfer still possible) | <code>dataExtractionRules</code> (cloud + device transfer exclude all) and <code>fullBackupContent</code> exclude all.                                                                                                                                          |
| <b>Transport</b>           | Platform defaults                                                             | <code>network_security_config</code> : cleartext off, system trust anchors only (user CAs not trusted); <code>usesCleartextTraffic=false</code> . Certificate pinning intentionally not added (Cloudflare rotates certificates; a bad pin would brick sign-in). |
| <b>Credential screens</b>  | Screenshots / Recents thumbnails allowed                                      | <code>FLAG_SECURE</code> on login and change-password; password never put in saved-state; password cleared after sign-in.                                                                                                                                       |
| <b>Logging</b>             | No logging found                                                              | Still none: no HTTP logging interceptor, no <code>Log.*</code> of tokens, bodies or credentials.                                                                                                                                                                |
| <b>External links</b>      | Any string starting with "http"; unguarded <code>startActivity</code>         | Only http(s) with a host (blocks <code>javascript:</code> , <code>intent:</code> , <code>file:</code> ); <code>CATEGORY_BROWSABLE</code> ; mailto/tel built with <code>Uri.fromParts</code> after validation; no WebView in the app.                            |
| <b>Selfie handling</b>     | Thumbnail bitmap in memory, compressed on main thread                         | Private cache file via non-exported FileProvider, subsampled decode (no 12 MP bitmaps), $\leq 960$ px JPEG 80, file deleted after upload; stale files swept after 1 h.                                                                                          |
| <b>Exported components</b> | Launcher activity                                                             | Launcher activity ( <code>singleTask</code> ) only; FileProvider <code>exported=false</code> ; AndroidX ProfileInstaller receiver is permission-protected.                                                                                                      |
| <b>Input validation</b>    | Minimal                                                                       | Workspace pattern, length caps on all text inputs, password policy aligned with web ( $\geq 12$ ), date-range rules, comment/ reason limits.                                                                                                                    |
| <b>Code shrinking</b>      | Off                                                                           | R8 on with keep rules: <code>com.pravahax.portalx.**</code> kept whole; OkHttp/Okio/coroutines consumer rules; kotlin.serialization rules. Toggle <code>-Pportalx.minify=false</code> .                                                                         |

Signing: v2 + v3 signatures with the unchanged key `portalx-release.jks` (certificate SHA-256 `AD:23:A0:3F:...:AF:48`, verified with `apksigner`). `applicationId` unchanged, so v0.2.0 installs over v0.1.4 and keeps the user's session (migrated to encrypted storage on first launch).

## Flow & logic fixes

---

### Auth state machine

- Explicit states: **Checking** → **SignedIn** | **Unavailable** | **SignedOut**, plus forced password change.
- Only a real 401 (or a narrow set of server messages) signs out; Cloudflare 5xx / offline keeps the cached session and shows a banner.
- Cold start with a session but no cache and no server: Unavailable screen with Retry, instead of dumping to login.
- Scope refresh is serialised with a mutex and retried once; concurrent 401s trigger one idempotent sign-out.
- Sign-out always wipes cookies, scope and the encrypted cache, even if the server call fails.
- Forced password change: 12-char policy, uses the server's returned user, can sign out.

### Attendance

- States: loading / on leave / not checked in / checked in / on break / complete, animated.
- Check-out asks for confirmation (shows the IST time) before the selfie.
- One attendance action at a time; disabled offline; "already checked in" re-reads state.
- Selfie survives camera-induced process death (saveable mode + file path).
- Timers and clock in IST, paused in background.
- Corrections: no future dates, 500-char note, reject requires confirmation.

### Leave

- Start/end/half-day rules, end  $\geq$  start enforced in the picker, half day locks end = start,  $\leq$  1 year ahead.
- Day count and an over-balance warning (server still decides).
- Reject asks for confirmation; approvals are single-flight per request.

### Tasks

- Status changes / swipe-to-done single-flight per task; rows are never removed optimistically.
- Overdue computed on IST calendar dates; comments use the web's `{body, author, at}` shape.
- Create task: title rules, past due dates blocked, project/assignee ids preserved.

### Data freshness

- Cached data shown instantly, then refreshed.
- Writes invalidate dependent reads (e.g. DecideLeave → MyLeave, PendingLeaveApprovals, DashboardStats, CalendarMonth).
- Auto-refresh on resume after 60 s; pull-to-refresh indicator only for user pulls; shimmer skeletons for first loads.

### Dates & time zone

- All parsing/display in Asia/Kolkata; day fields converted to IST before taking the date (fixes off-by-one for IST-midnight DATE values).

### Lifecycle

- Repo/HTTP stack are process singletons; form state survives rotation; no global `!!` holders.

## UI & design changes

The app now uses the **exact design tokens** of `portal.pravahax.com/assets/app-CR0H90FW.css`. The web re-maps Tailwind's `slate` to a warm parchment/umber scale and `indigo` to brand gold; v0.1.4 used cool Tailwind slate (`#020617`, `#F8FAFC`) and a stray indigo secondary, which did not match the site. Fonts: **Manrope** (`--font-sans`, variable 200–800) for UI and **Playfair Display** (`--font-display` / `--font-serif`, variable 400–900) for headings — the bundled files were verified to be exactly these families, so no download was needed. The web has no dark theme; the app's dark scheme is built only from the web's own dark tokens.

| TOKEN                                                                                                      | WEB VARIABLE                         | HEX                  | APP ROLE                                          |
|------------------------------------------------------------------------------------------------------------|--------------------------------------|----------------------|---------------------------------------------------|
|  <b>Primary</b>           | <code>--portal-primary</code>        | <code>#B8832B</code> | primary (light)                                   |
|  <b>Secondary</b>         | <code>--portal-secondary</code>      | <code>#C8953C</code> | secondary (light)                                 |
|  <b>Primary soft</b>      | <code>--portal-primary-soft</code>   | <code>#F4EADB</code> | primaryContainer                                  |
|  <b>Secondary soft</b>    | <code>--portal-secondary-soft</code> | <code>#F7EDE0</code> | secondaryContainer                                |
|  <b>Slate 50</b>          | <code>--color-slate-50</code>        | <code>#FBFAF7</code> | background (light)                                |
|  <b>Slate 100</b>         | <code>--color-slate-100</code>       | <code>#F4F0E7</code> | surfaceVariant; onSurface (dark)                  |
|  <b>Slate 200</b>        | <code>--color-slate-200</code>       | <code>#E7DFD0</code> | outlineVariant / card hairline                    |
|  <b>Slate 300</b>       | <code>--color-slate-300</code>       | <code>#D2C4AC</code> | outline                                           |
|  <b>Slate 400</b>       | <code>--color-slate-400</code>       | <code>#AE9D83</code> | onSurfaceVariant (dark)                           |
|  <b>Slate 600</b>       | <code>--color-slate-600</code>       | <code>#6F5E4A</code> | onSurfaceVariant (light)                          |
|  <b>Slate 800</b>       | <code>--color-slate-800</code>       | <code>#352C24</code> | onSurface (light);<br>surfaceContainerHigh (dark) |
|  <b>Slate 900</b>       | <code>--color-slate-900</code>       | <code>#282018</code> | onBackground (light); surface (dark)              |
|  <b>Slate 950</b>       | <code>--color-slate-950</code>       | <code>#17120E</code> | background (dark); splash; launcher bg            |
|  <b>Gold 400</b>        | <code>--color-indigo-400</code>      | <code>#CF9E42</code> | primary (dark)                                    |
|  <b>Gold 900</b>        | <code>--color-indigo-900</code>      | <code>#563715</code> | onPrimaryContainer (light)                        |
|  <b>Gold 950</b>        | <code>--color-indigo-950</code>      | <code>#30200F</code> | primaryContainer (dark)                           |
|  <b>Hero top</b>        | <code>platform-login-intro</code>    | <code>#241A10</code> | brand panels, hero card                           |
|  <b>Hero bottom</b>     | <code>platform-login-intro</code>    | <code>#100D0A</code> | brand panel gradient end                          |
|  <b>Kicker on dark</b>  | <code>.platform-eyebrow</code>       | <code>#E0BD76</code> | eyebrow on dark                                   |
|  <b>Kicker on light</b> | <code>.platform-step-label</code>    | <code>#9B6C1C</code> | eyebrow on light                                  |
|  <b>Danger</b>          | <code>.platform-danger-action</code> | <code>#B42318</code> | error (light)                                     |
|  <b>Danger soft</b>     | <code>.platform-danger-action</code> | <code>#FFF5F4</code> | errorContainer (light)                            |
|  <b>Shadow ink</b>      | <code>--shadow-soft</code>           | <code>#15110D</code> | card shadow tint                                  |

## Status colours (Tailwind v4 oklch tokens converted to sRGB)

| tone    | web token (light / dark) | light                                                                                     | dark                                                                                        |
|---------|--------------------------|-------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| Success | green-700 / green-500    |  #008236 |  #00C950 |
| Warning | amber-700 / amber-500    |  #BB4D00 |  #FE9A00 |
| Danger  | red-600 / red-500        |  #E7000B |  #FB2C36 |
| Info    | blue-700 / blue-200      |  #1447E6 |  #BEDBFF |
| Accent  | purple-700 / purple-500  |  #8200DB |  #AD46FF |
| Neutral | slate-600 / slate-400    |  #6F5E4A |  #AE9D83 |

## Type, shape and spacing

- Type scale mirrors the web (12/14/16/18/20/24/30/36 sp); display styles in Playfair Display SemiBold with the web's `tracking-tight` (−0.025em); uppercase kickers with 0.2em tracking.
- Radii from the web: 6 / 8 / 16 / 22 dp ( `radius-md`/`lg`/`xl`/`2xl` ), 24 dp for hero panels. Cards = the web's `.portal-panel`: white, slate-200 hairline, `shadow-soft` tinted #15110D.
- 4 dp spacing scale (web `--spacing: .25rem`) applied consistently.

## Screens

- **Login**: the web's AuthLayout — dark brand panel with gold glow and hairline, Playfair headline, the web's copy; sheet-style form; secure window; light status-bar icons.
- **Home**: date kicker, Playfair greeting, dark brand attendance hero (gold while working, live "worked so far"), stat tiles, task and leave summaries, unread dots.
- **Attendance**: haloed gold check-in button, large IST clock and work timer, status chips, animated state changes.
- Shimmer skeletons instead of spinners; halo-illustrated empty states; dot status chips; gradient initials avatars; refined bottom navigation (hairline, gold-soft indicator, haptic tick); app-wide offline bar; edge-to-edge insets handled per screen.

## Known limitations & unverified

---

- **Authenticated response shapes.** No credentials were available in the sandbox. Field names were verified against the web bundle (attendance, leave, tasks, user normalisation), but these remain inferred: DashboardDetails lists, Corrections `status / note`, TaskDetail `creator`, CalendarMonth meeting date fields, Directory `email / phone`. The UI is defensive (tested with hostile payloads) — wrong shapes show empty states, never crashes.
- **Write flows not exercised live.** By design no create/edit/delete server function was called against the live portal. Check-in/out, breaks, corrections, leave apply/decide, task create/update/comment and mark-read need one pass on a real account.
- **R8 build not run on a device.** Robolectric executes JVM bytecode, not the minified DEX, so the launch test cannot run against the R8 output. Mitigations: the app's own package is kept whole, the R8 output was inspected (382 app classes present; coroutines Main-dispatcher ServiceLoader correctly rewritten), and `./gradlew assembleRelease -Pportalx.minify=false` rebuilds an un-shrunk APK if anything misbehaves. **Recommended:** install v0.2.0, sign in, open each tab, check in on a test day.
- **Server-function hash fragility.** All calls target `/_serverFn/<sha256>` ids copied from the current web build; any web redeploy changes them and every call fails (the app now says "This feature isn't available right now. The app may need an update." instead of signing out). Recommended: a versioned JSON API (`/api/mobile/v1/...`) sharing the session cookie and scope header, or at minimum a stable `/mobile-manifest.json` mapping names to current hashes that the app fetches at start-up.
- **Portal availability.** During the audit the portal intermittently returned Cloudflare `530 / error 1033` (tunnel down). The app handles it gracefully, but it affects users.
- **Keystore edge cases.** On devices whose Keystore is broken, the session is memory-only and users sign in after each restart (secure by design). Restoring onto a new device also requires a fresh sign-in.
- **Web-only modules** (projects, documents, performance, feedback, admin) open in the browser, which has its own sign-in.
- **Time zone.** The app shows all times in IST. Staff outside India would see office time rather than local time.
- **No certificate pinning** (deliberate; see Security review).

## Testing done

| SUITE                                              | TESTS | WHAT IT PROVES                                                                                                                                                                                                                                                                                                                        |
|----------------------------------------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>LaunchTest</b> (Robolectric)                    | 1     | MainActivity launches to RESUMED ( <code>LAUNCH_OK state=RESUMED</code> ) with the new Application, splash, theme and secure window.                                                                                                                                                                                                  |
| <b>UiSmokeTest</b> (Robolectric + MockWebServer)   | 2     | Signs in against a mock portal, then renders all 11 screens (Home, Attendance, Tasks, Calendar, More, Leave, Meetings, Announcements, Directory, Profile, Login) in light and dark, with realistic fixtures and with hostile payloads (wrong types, nulls, duplicate/missing ids, bad dates, inverted ranges): 44 renders, 0 crashes. |
| <b>PortalApiTest</b> (Robolectric + MockWebServer) | 7     | Server-fn headers and scope; scope refresh + single retry; null user ⇒ 401; business errors (e.g. "Invalid User ID or password.") are not sign-outs; Cloudflare 530 HTML ⇒ friendly, non-401; GET retried once, POST never replayed; cookies persisted, sent and cleared.                                                             |
| <b>SerovalTest</b>                                 | 6     | Request encoding; escape round-trip; refs, Date, BigInt, Map, \$TSR/Error plugin decoding; totality on garbage and mismatched arrays.                                                                                                                                                                                                 |
| <b>HelpersTest</b>                                 | 5     | Id preservation (no 0 fallback); unique list keys; tolerant accessors; role/permission logic; invalidation map.                                                                                                                                                                                                                       |
| <b>DatesAndValidationTest</b>                      | 6     | IST day bucketing (incl. IST-midnight case); IST time display; overdue; durations; leave/correction/password/login/URL validation.                                                                                                                                                                                                    |
| <b>Total</b>                                       |       | <b>27 tests, 0 failures, 0 errors</b> ( <code>sh /workspace/work/rtest.sh</code> → <code>EXIT 0</code> ).                                                                                                                                                                                                                             |

### Build verification

- `./build.sh` (assembleRelease, R8 + resource shrinking): success. **PortalX.apk 2,240,541 bytes** (v0.1.4: 11,960,598).
- `aapt2 dump badging: com.pravahax.portalx.mobile`, versionCode 6, versionName 0.2.0, min 26, target 35.
- `apksigner verify`: v2 + v3 valid, one signer, certificate SHA-256 equals the keystore's.
- Merged manifest: allowBackup=false, dataExtractionRules, networkSecurityConfig, usesCleartextTraffic=false, FileProvider not exported.
- Read-only probes of the live site were limited to fetching the public CSS (design tokens).